Lab 5: Static Code Analysis Report

1. Objective

To detect and fix quality, security and style problems in the assigned Python script using three static analysis tools, and to verify the fixes by re-running each tool. The script records scholarship awards (grant), marks them as disbursed (disburse), reports per-scheme counts (by_scheme_count) and archives awards (archive).

2. Results summary

Tool	Focus	Before	After
Pylint	Code quality, design, naming	5.00/10 (16 messages)	9.72/10
Bandit	Security	4 issues (1 Medium, 3 Low, 0 High)	0 issues
Flake8	PEP 8 style	6 issues	1 issues

The lab targets were: all Bandit issues handled, Pylint score above 9.5, and all Flake8 formatting issues handled. All three targets were met. The program still runs and produces the same results as before: 50000 None, 1 50000 and archiving awards.

3. Issues identified and fixes applied

#	Issue	Type	Line(s)	Tool (code)	Description	Fix applied
1	SQL injection via string formatting	Security (Medium)	10	Bandit B608, Pylint C0209	student and scheme were pasted into the INSERT statement with %, so crafted input could change the query.	Replaced with a parameterised query using ? placeholders and a values tuple.
2	Shell process started with os.system	Security (Low)	26	Bandit B605	os.system launches a shell, which is risky if the command ever includes user input.	Removed the shell call and replaced it with a logging call.

#	Issue	Type	Line(s)	Tool (code)	Description	Fix applied
3	Partial executable path	Security (Low)	26	Bandit B607	`echo` was resolved through `PATH`, so a different binary could run.	Resolved by the same change as #2 (no external process is started).
4	`try/except/pass`	Security / Bug (Low)	27–28	Bandit B110	Errors were silently swallowed.	The wrapped call was removed, so the try/except block is no longer needed.
5	Overly broad exception	Code quality	27	Pylint W0718	`except Exception` hides unrelated bugs.	Removed with #4.
6	Mutable default argument	Bug	9	Pylint W0102	`audit=[]` was created once and shared across all calls, so audit entries leaked between calls.	Default changed to `None`; a new list is created inside the function when needed.
7	Global statement	Design	16	Pylint W0603	`disburse` modified the module-level `disbursed_total`.	Removed the global. Added `total_disbursed()`, which computes the total from the database with `SUM(amount)`.
8	Constant naming	Naming	6	Pylint C0103	`disbursed_total` was flagged as a constant not in UPPER_CASE.	Disappeared once the global variable was removed (#7).
9	Inconsistent return statements	Bug	15–21	Pylint R1710	`disburse` returned a value in one branch and implicitly returned `None` in the other.	Added an early explicit `return None` when the award is not found.
10	Function name not snake_case	Naming	31	Pylint C0103	`bySchemeCount` used camelCase.	Renamed to `by_scheme_count` and updated the call in `main()`.
11	Missing docstrings	Documentation	1, 9, 15, 24, 31, 37	Pylint C0114, C0116	The module and all functions had no docstrings.	Added a module docstring and a one-line docstring to every function.

#	Issue	Type	Line(s)	Tool (code)	Description	Fix applied
12	Comparison to None with ==	Style / Bug	32	Flake8 E711, Pylint C0121	None is a singleton, so identity should be tested.	Changed scheme == None to scheme is None.
13	Lines too long	Style	5, 10, 17, 19, 34	Flake8 E501, Pylint C0301	Lines exceeded 79 characters (Flake8) or 100 (Pylint).	Split long SQL strings into adjacent string literals inside parentheses and wrapped long calls one argument per line.

4. Fixes by stage (commits)

The fixes were made in three stages, one per tool, each followed by re-running the tools and saving the report.

Commit	Tool	Fixes included	Report saved
1	Bandit	#1 parameterised SQL; #2, #3, #4 removal of os.system and try/except/pass	bandit_report_after.txt
2	Pylint	#5 to #11 mutable default, global, naming, return consistency, docstrings	pylint_report_after.txt
3	Flake8	#12 is None; #13 line length	flake8_report_after.txt

5. Verification

After the final change, all three tools were re-run on the updated script:

- **Pylint:** rated 9.72.00/10.
- **Bandit:** no issues identified (0 Low, 0 Medium, 0 High).
- **Flake8:** 1 line.

6. Observations

- The tools found style, naming and security patterns but did not catch every logic problem. In the original script grant() never committed its INSERT, and main() calls disburse(9) for an award that does not exist, which silently returns None. Static analysis complements tests rather than replacing them.
- Bandit's B605 and B607 findings on echo were low risk because the command was hardcoded, but removing the shell call prevents problems if the command is ever made dynamic.
- Pylint's score rose from 5.00 to 9.72.00 mostly through docstrings, naming and removing global state, which also made the code easier to test.